

Multi-Factor Authentication Policy

1. Purpose

This policy mandates the use of multi-factor authentication (MFA) for access to all Summit IT Services systems and establishes requirements for acceptable MFA methods, enrollment, and management. MFA significantly reduces the risk of unauthorized access resulting from compromised credentials. Summit IT Services uses **Okta Verify** as the primary MFA platform, with **YubiKey hardware tokens** required for privileged and high-risk access scenarios.

2. Scope

This policy applies to:

- All employees, contractors, interns, temporary workers, and third-party vendors with user accounts in Summit IT Services systems.
- All systems integrated with Okta for Single Sign-On (SSO), including Microsoft 365, Slack, Zoom, SummitDesk, 1Password, AWS, CrowdStrike, Intune, Jamf Pro, and all internally hosted applications.
- Any application with its own authentication layer not yet federated to Okta (these must be enrolled in Okta or an exception must be filed).
- Remote and on-premises access scenarios alike - MFA is required at all times, not only off-network.

3. Policy Statements

3.1 MFA Enrollment Requirements

3.1.1 MFA enrollment in Okta is mandatory for every user account. Enrollment must be completed within **48 hours** of account provisioning. Accounts not enrolled within this window will be automatically restricted to read-only access until enrollment is complete.

3.1.2 Every user must enroll at least **two** MFA factors to ensure backup access. Recommended primary and backup factor combinations are listed in Section 3.2.

3.1.3 MFA enrollment is initiated through the Okta End-User Dashboard at <https://summitit.okta.com> under **Settings > Security Methods**. IT Service Desk (L1) can assist with enrollment at servicedesk@summitit.com or [#it-help](#).

3.1.4 New employees will receive MFA enrollment instructions during IT onboarding. Completion is verified by IT before full system access is granted.

3.2 Approved MFA Methods

The following MFA methods are approved for use at Summit IT Services, ranked by security assurance level:

Tier	Method	Tool / Device	Allowed For
1 - Highest	Hardware security key (FIDO2/WebAuthn)	YubiKey 5 Series	All users; required for privileged roles
2 - High	Okta Verify push notification	Okta Verify app (iOS / Android)	All users
3 - High	Okta Verify TOTP (time-based OTP)	Okta Verify app	All users (backup)
4 - Medium	Biometric (Face ID / Touch ID via Okta FastPass)	Device biometric	All users on enrolled devices
5 - Low (limited)	SMS one-time passcode	Carrier SMS	Backup only; not for privileged access

3.2.1 **SMS OTP is considered a low-assurance factor** due to SIM-swap risk. It is permitted only as a secondary backup factor and must not be the sole or primary MFA method for any account. Privileged accounts must not use SMS OTP at all.

3.2.2 Authenticator apps not officially supported by Okta (e.g., third-party TOTP apps) may be approved as secondary factors only with IT Security approval.

3.2.3 Voice call OTP is not approved and is disabled in Okta.

3.2.4 Email-based OTP to corporate email is not considered a valid second factor because the email account itself is protected by MFA. It is disabled in Okta.

3.3 Privileged Account MFA Requirements

3.3.1 Accounts with elevated privileges - including Okta administrators, Microsoft 365 Global Administrators, AWS IAM privileged roles, Intune/Jamf administrators, CrowdStrike administrators, and local device administrators - must use a **YubiKey 5 Series** hardware key as their primary MFA factor.

3.3.2 YubiKey tokens for privileged accounts are issued and tracked by the IT Security & Compliance team. Each YubiKey is registered in the IT Asset Management system with the assigned user's name and employee ID.

3.3.3 Privileged accounts must not authenticate using SMS OTP or push notification alone. A phishing-resistant factor (FIDO2/YubiKey) is mandatory for all privileged sessions.

3.3.4 Privileged access sessions have a maximum session lifetime of **8 hours** in Okta. Re-authentication with MFA is required after this window.

3.4 Session Management and Step-Up Authentication

3.4.1 Standard user Okta sessions remain active for up to **12 hours** during an active workday. Inactive sessions (no interaction) expire after **30 minutes**.

3.4.2 Accessing high-risk applications or performing sensitive operations (e.g., changing MFA settings, accessing HR data, exporting bulk records) triggers an Okta **step-up authentication** prompt requiring re-verification of a high-assurance factor.

3.4.3 When connecting via GlobalProtect VPN, Okta MFA is required at connection time. VPN sessions are re-evaluated every **8 hours**.

3.4.4 Users must not approve Okta push notifications they did not initiate. Any unexpected MFA push must be **denied** immediately and reported to the SOC at soc@summitit.com or via [#it-help](#) on Slack.

3.5 Device Trust and Managed Devices

3.5.1 Okta Device Trust is enforced for access to sensitive applications. Only devices enrolled in **Microsoft Intune** (Windows) or **Jamf Pro** (macOS) and meeting compliance policy are granted access.

3.5.2 Unmanaged personal devices may access a limited set of low-sensitivity applications (e.g., Outlook Web App with no download capability) only after completing MFA, and only where the application's risk profile permits.

3.5.3 Employees who access Summit IT systems from a personal or unmanaged device must ensure the device is running a supported OS version, has up-to-date security patches applied, and does not have elevated risk indicators.

3.6 Lost, Stolen, or Compromised MFA Devices

3.6.1 If an MFA device (phone running Okta Verify, or YubiKey) is lost, stolen, or compromised, the employee must:

1. Immediately notify the IT Service Desk at +1 (800) 555-7866 or servicedesk@summitit.com.
2. The Service Desk will disable MFA factors associated with the lost device within 30 minutes of notification.
3. The employee will be issued a one-time temporary access code to re-enroll MFA from a verified device.
4. For lost YubiKeys assigned to privileged accounts, the SOC must also be notified and the account suspended until a replacement YubiKey is issued and enrolled.

3.6.2 A lost YubiKey replacement will be issued within one business day. The lost device must be reported to the IT Asset Management team for removal from inventory.

3.6.3 Employees must not attempt to restore or transfer Okta Verify accounts between phones without IT assistance, as this may result in loss of MFA access.

3.7 MFA Bypass and Exceptions

3.7.1 MFA bypass for any account or application is prohibited without an approved exception documented in the IT GRC system.

3.7.2 Temporary MFA bypass (e.g., for a user traveling to a location with unreliable phone signal) requires advance written approval from IT Security and must be limited to the shortest feasible window, not to

exceed 7 days.

3.7.3 Automated service accounts and CI/CD pipelines must use API keys or OAuth service credentials rather than bypassing MFA. Any automated access must be reviewed by IT Security during system onboarding.

4. Roles & Responsibilities

Role	Responsibility
All Employees	Enroll MFA within 48 hours; maintain at least 2 factors; immediately report lost/compromised devices; never approve unexpected MFA prompts
IT Service Desk (L1)	Assist with enrollment; process device-loss notifications; issue temporary codes per identity-verification procedure
IT Security & Compliance	Own and maintain this policy; configure Okta MFA policies; monitor enrollment compliance; investigate MFA bypass attempts
L2 Desktop & Systems	Issue and track YubiKeys; assist with enrollment on managed devices
L3 Engineering	Implement and maintain Okta MFA, Device Trust, and Adaptive MFA policies; integrate new applications with Okta SSO
SOC	Respond to suspicious MFA events; investigate repeated push denials or impossible travel alerts
Managers	Ensure new team members complete MFA enrollment; notify IT immediately when team members leave

5. Enforcement & Consequences

5.1 Technical enforcement is the primary control: Okta policies deny access to MFA-required applications if no valid second factor is presented. These controls cannot be bypassed without IT Security involvement.

5.2 Policy violations (e.g., sharing MFA codes, approving MFA for another person, attempting to disable MFA) will be investigated:

- **Sharing or approving MFA for another user:** Formal written warning; mandatory security training; escalation to HR.

- **Disabling or circumventing MFA controls:** Immediate account suspension; HR investigation; potential termination.
- **Failure to report lost MFA device in a timely manner:** Written warning; review of any access that occurred during the gap.

6. Exceptions

Exceptions must be submitted via SummitDesk as a Policy Exception Request and require:

1. Documented technical or operational justification.
2. Risk acceptance signed by the employee's VP-level manager and the CISO.
3. Defined time limit (maximum 30 days; renewable only with re-approval).
4. Compensating controls (network restriction, enhanced logging, anomaly alerting).

7. Related Documents

- POL-002 - Password & Authentication Policy
- POL-001 - Acceptable Use Policy
- POL-006 - Remote Work IT Policy
- POL-009 - Access Control & Least Privilege Policy
- REF-0001 - Summit IT Environment Standards
- Okta MFA Configuration Guide (internal wiki)
- YubiKey Issuance Procedure (internal runbook)

8. Revision History

Version	Date	Author	Summary of Changes
1.0	2022-03-01	IT Security	Initial MFA policy; mandated Okta Verify for all users
1.1	2022-10-15	IT Security	Added YubiKey requirement for privileged accounts
2.0	2024-06-01	IT Security & Compliance	Added Device Trust, Okta FastPass, step-up authentication; deprecated voice OTP

2.1	2026-02-10	IT Security & Compliance	Annual review; clarified SMS OTP restrictions; updated VPN re-auth window to 8 hours
-----	------------	--------------------------	--